

ASHAKids | Auditoría del backend

Corte 2026-10-09-13: correcciones B01-B06 y verificación real en Supabase. Fecha: 9 de octubre de 2026, America/Lima. Evaluación técnica asistida; no certificación clínica, pentest ni despliegue de producción.

Repositorio: <https://github.com/sromansilva/ashakids-platform> . Rama de implementación: piero-dev. SHA funcional auditado: b76a34a6125cae42614e9bee6da41ccc28163d7b, V20_Correccion_Backend_Seguridad_Contratos. Base publicada: V19/a1930df456aed94a727acfa4625ef32a7bc6385d. El complemento de verificación y este informe se incorporan después de V20; no modifican el runtime auditado.

Entorno: Windows, Python 3.13.7, FastAPI 0.143.0, SQLAlchemy 2.1.4, asyncpg 0.32.0, Pydantic 2.14.0 y ReportLab 4.5.1; PostgreSQL 17.6 configurado en backend/.env privado y alojado en Supabase. API habitual 127.0.0.1:8000; proxy frontend del equipo en 5174. No se usaron puerto 8001 ni bases descartables. Entrega académica: 2026-10-09, 18:00 Lima.

01. Dictamen ejecutivo

Valoración técnica: 83/100, frente al 73/100 histórico. Se corrigieron TLS, protección local del login, reglas duplicadas y mantenimiento. Se comprobó concurrencia acotada del núcleo con Supabase. El rol de BD sigue privilegiado y falta verificar hosting HTTPS, rotación y recuperación. Esta valoración usa las seis dimensiones del Word anterior; no es porcentaje de cobertura ni calificación oficial del profesor.

Criterio / máximo	Anterior	Actual	Fundamento y límite
Funciones y persistencia / 30	27	28	Núcleo, variantes y seis huecos HTTP previos comprobados. DELETE físicos y aceptación visual exhaustiva pendientes.
Modelo y conexión / 15	14	15	Modelo físico real, 19 modelos sin diferencias de columnas y TLS con cadena/nombre más prueba negativa. No certifica todos los defaults.
Seguridad y permisos / 20	8	13	TLS, límites y recuperación, cookies/origen HTTPS en unidades, roles y revocación real. Restan privilegios mínimos, rotación y protección distribuida.
Operación y publicación / 15	8	9	Timeouts, errores seguros, readiness y publicación Git. Hosting HTTPS, recuperación, backup y operación distribuida pendientes.
Validaciones y errores / 10	8	9	Contraseñas y sexo compartidos, parcial/null/datos antiguos y 422. No todas las variantes de cada payload.
Pruebas y mantenimiento / 10	8	9	114 unidades sin BD, HTTP/SQL real y refactor compatible. No suite destructiva completa, carga ni QA visual nuevo.
Total / 100	73	83	Los pendientes externos no se dan por resueltos.

Indicador	Resultado nuevo	Alcance
Inventario OpenAPI	55 operaciones de negocio y sistema	/openapi.json es un mecanismo auxiliar; no se suma como operación 56.
HTTP final	99 recorrido + 29 complemento + 5 sistema = 133 respuestas esperadas; 0 fallos	53/55 operaciones con respuesta positiva real. No todos los permisos, parámetros ni escenarios.
Backend	114 aprobadas, 0 fallidas, 0 omitidas; 19 avisos	183 recolectadas; 69 no ejecutadas. Selección sin BD ni conftest.
Frontend	257 componentes + 25 rutas aprobados; tipos/check/build correctos	Regresión automatizada; no auditoría visual nueva de todas las pantallas.
Persistencia final	2 reservas, 2 sesiones finalizadas, 1 reporte completo, 2 mensajes; 0 sesiones auth nuevas activas	SQL READ ONLY y reporte idéntico tras relogin.

Se conservan también 95 respuestas de la primera cohorte y 24 del complemento inicial. No se suman como casos diferentes a las 133 finales. La primera concurrencia compartía sesión de login: ultima_actividad podía serializarla antes del servicio. La corrida final utiliza sesiones distintas. Las 103 respuestas, 47/55 contratos y 63 pruebas del informe anterior son evidencia heredada.

02. Arquitectura y cambios realizados

React -> cliente HTTP/JSON -> FastAPI -> servicios/Pydantic -> SQLAlchemy/asyncpg -> PostgreSQL en Supabase. Se conservan Argon2id, sesiones opacas hasheadas, cookie HttpOnly, roles PADRE/TERAPEUTA/ADMIN y autorización por recurso. Sin Supabase Auth, acceso directo desde React, módulos nuevos ni rediseño frontend.

TLS remoto usa CERT_REQUIRED y check_hostname=True con CA privada configurada. La conexión válida negoció TLS 1.3/TLS_AES_256_GCM_SHA384; una trust store vacía fue rechazada. El primer intento falló con código 92 porque la CA 2021 carece de keyUsage. DB_SSL_LEGACY_CA permite explícitamente ese formato y está desactivada por defecto; conserva cadena, vigencia y nombre. Retirar la excepción cuando el proveedor entregue una cadena compatible. Referencia: <https://docs.python.org/3.13/library/ssl.html>.

Producción exige entorno y orígenes HTTPS explícitos; rechaza escrituras recibidas por HTTP. Login limita por IP e IP/código, con ventana fija y memoria acotada. Las rechazadas no prolongan el bloqueo ni bloquean globalmente una cuenta desde otra IP. Estado local a un proceso: reinicios lo borran y no coordina réplicas. WEB_CONCURRENCY es una guarda de configuración, no detecta workers fijados por CLI. Decisión y límites: ADR 0009 y operations/BACKEND_SECURITY_CONFIGURATION.md.

Administración se divide en lectura, creación, estado, eliminación y auditoría; admin_service conserva imports públicos y edición. La serialización de pacientes se separa de operaciones SQL. Comparación AST: 14 funciones administrativas y 13 de pacientes mantienen cuerpos idénticos. Todos los Python modificados tienen como máximo 500 líneas; máximo observado 499. No cambios generales de carpetas ni dependencias runtime.

Contraseñas nuevas: 12-128 caracteres en usuarios y administración; ese mínimo no se aplica al login. Escritura de sexo admite M/F/OTRO y palabras, normaliza a Masculino/Femenino/Otro; lectura preserva valores existentes sin migrar filas. Nombres vacíos y nacimiento futuro se rechazan en ambas familias. No se bloquea edición de datos antiguos por edad actual. Null explícito en PATCH hijos se rechaza; campos omitidos se conservan.

FOR UPDATE refresca el estado ORM con populate_existing. Commit previo al éxito y rollback se conservan; fallo de rollback no sustituye el error inicial. Deadlock/serialización e integridad devuelven 409; conexión/timeouts, 503. Sin reintentos automáticos, migraciones ni restricciones nuevas.

Modelo físico leído: 26 tablas, 178 columnas, 92 restricciones (26 PK, 34 FK, 13 UNIQUE, 19 CHECK), 71 índices y 26 secuencias. 19 tablas ORM: 0 diferencias de columnas/tipos/nulabilidad/longitud/precisión inspeccionadas. Relaciones: usuario -> roles/perfiles/sesiones auth; tutor -> paciente -> expediente -> tratamiento; profesional -> tratamiento/cita; reserva -> sesión -> reporte; tutor/profesional -> conversación -> mensajes. RLS habilitada, 0 políticas públicas; el rol actual omite RLS. Metadatos no certifican todos los defaults, reglas ni autorización de cada fila.

03. APIs verificadas: identidad y pacientes

Matriz nueva por operación: A=ADMIN; P=PADRE; T=TERAPEUTA; Prop=cuenta propia. En clínica se exige pertenencia por familia/asignación; el rol solo no concede acceso. Confirmar cita requiere A/T; cancelar puede hacerlo el participante autorizado. L=live-supabase.json; F=followup-supabase.json; S=system-http.json. Resultado incluye caso, esperado/obtenido y evidencia. operation-matrix.json conserva cada actor y caso individual.

Método y ruta	Rol	Caso / esperado-obtenido / evidencia
POST /api/v1/auth/login	Público	Escritura; esperado=obtenido: 200. F,L.
POST /api/v1/auth/logout	Token opc.	Escritura; esperado=obtenido: 200. F,L.
GET /api/v1/auth/me	Sesión	Lectura; esperado=obtenido: 200, 401. F,L,S.
GET /api/v1/padres/me	P	Lectura; esperado=obtenido: 200. L.
GET /api/v1/padres/hijos	P	Lectura; esperado=obtenido: 200. F.
POST /api/v1/padres/hijos	P	Escritura; esperado=obtenido: 201, 422. L.
GET /api/v1/padres/hijos/{id_paciente}	P	Lectura; esperado=obtenido: 200. F.
PATCH /api/v1/padres/hijos/{id_paciente}	P	Escritura; esperado=obtenido: 200. L.
DELETE /api/v1/padres/hijos/{id_paciente}	P	DELETE físico sin ensayo: fuera de autorización.
PATCH /api/v1/padres/hijos/{id_paciente}/inactivar	P	Escritura; esperado=obtenido: 200. F.
GET /api/v1/terapeutas/me	T	Lectura; esperado=obtenido: 200. L.
GET /api/v1/admin/me	A	Lectura; esperado=obtenido: 200. L.
GET /api/v1/admin/cuentas	A	Lectura; esperado=obtenido: 200. F.
GET /api/v1/admin/cuentas/{id_usuario}	A	Lectura; esperado=obtenido: 200. F.
PATCH /api/v1/admin/cuentas/{id_usuario}	A	Escritura; esperado=obtenido: 200. F.
DELETE /api/v1/admin/cuentas/{id_usuario}	A	DELETE físico sin ensayo: fuera de autorización.
POST /api/v1/admin/cuentas/padres	A	Escritura; esperado=obtenido: 201, 422. L.
POST /api/v1/admin/cuentas/terapeutas	A	Escritura; esperado=obtenido: 201, 422. L.
PATCH /api/v1/admin/cuentas/{id_usuario}/suspender	A	Escritura; esperado=obtenido: 200. L.
PATCH /api/v1/admin/cuentas/{id_usuario}/activar	A	Escritura; esperado=obtenido: 200. L.
GET /api/v1/admin/cuentas/{id_usuario}/hijos	A	Lectura; esperado=obtenido: 200. F.
PATCH /api/v1/admin/pacientes/{id_paciente}/reactivar	A	Escritura; esperado=obtenido: 200. F,L.
GET /api/v1/usuarios	A	Lectura; esperado=obtenido: 200. F.
POST /api/v1/usuarios	A	Escritura; esperado=obtenido: 201, 422. L.

Método y ruta	Rol	Caso / esperado-obtenido / evidencia
GET /api/v1/usuarios/{key}	A	Lectura; esperado=obtenido: 200. L.
PATCH /api/v1/usuarios/{key}	A/Prop.	Escritura; esperado=obtenido: 200. F.
GET /api/v1/pacientes	A/P/T	Lectura; esperado=obtenido: 200. F.
POST /api/v1/pacientes	A/P	Escritura; esperado=obtenido: 201, 422. L.
GET /api/v1/pacientes/{key}	A/P/T	Lectura; esperado=obtenido: 200, 404. F,L.
PUT /api/v1/pacientes/{key}	A/P	Escritura; esperado=obtenido: 200. L.
DELETE /api/v1/pacientes/{key}	A/P	Escritura; esperado=obtenido: 200. L.
GET /api/v1/pacientes/{key}/tratamientos	A/P/T	Lectura; esperado=obtenido: 200. F.
POST /api/v1/tratamientos	A	Escritura; esperado=obtenido: 201. L.

Seis de los ocho huecos históricos tienen evidencia HTTP nueva: POST hijos, POST cuentas padres/terapeutas, DELETE pacientes (lógico), PUT citas y GET conversaciones. DELETE hijos y DELETE cuentas son físicos y no se invocaron. Se conservan contratos y comprobaciones de dependencia existentes; no se simula borrado real para declararlos verificados.

04. APIs verificadas: citas, sesiones, mensajería y sistema

Método y ruta	Rol	Caso / esperado-obtenido / evidencia
GET /api/v1/citas	A/P/T	Lectura; esperado=obtenido: 200. F.
POST /api/v1/citas	A/P/T	Escritura; esperado=obtenido: 201, 409. L.
GET /api/v1/citas/{key}	A/P/T	Lectura; esperado=obtenido: 200, 404. F,L.
PUT /api/v1/citas/{key}	A/P/T	Escritura; esperado=obtenido: 200. L.
PATCH /api/v1/citas/{key}/estado	A/P/T	Escritura; esperado=obtenido: 200, 403. L.
GET /api/v1/sesiones	A/P/T	Lectura; esperado=obtenido: 200. F.
POST /api/v1/sesiones	A/T	Escritura; esperado=obtenido: 201, 409. L.
GET /api/v1/sesiones/{key}	A/P/T	Lectura; esperado=obtenido: 200, 404. F,L.
POST /api/v1/sesiones/{key}/iniciar	A/T	Escritura; esperado=obtenido: 200, 409. L.
POST /api/v1/sesiones/{key}/cerrar	A/T	Escritura; esperado=obtenido: 200, 409. L.
GET /api/v1/sesiones/{key}/reporte	A/P/T	Lectura; esperado=obtenido: 200, 404. L.
PUT /api/v1/sesiones/{key}/reporte	A/T	Escritura; esperado=obtenido: 200, 422. L.
GET /api/v1/sesiones/{key}/reporte/pdf	A/P/T	Lectura; esperado=obtenido: 200, 404. L.
GET /api/v1/conversaciones/contactos	P/T	Lectura; esperado=obtenido: 200. F.
GET /api/v1/conversaciones	P/T	Lectura; esperado=obtenido: 200. L.
POST /api/v1/conversaciones	P/T	Escritura; esperado=obtenido: 200. L.
GET /api/v1/conversaciones/{key}	P/T	Lectura; esperado=obtenido: 200, 403, 404. F,L.
GET /api/v1/conversaciones/{key}/mensajes	P/T	Lectura; esperado=obtenido: 200. L.
POST /api/v1/conversaciones/{key}/mensajes	P/T	Escritura; esperado=obtenido: 201, 422. L.
GET /	Público	Lectura; esperado=obtenido: 200. S.
GET /health	Público	Lectura; esperado=obtenido: 200. S.
GET /health/ready	Público	Lectura; esperado=obtenido: 200. S.

Sesiones auth distintas para cada solicitud concurrente: reserva 201/409 y una sola cita; creación de sesión 201/409 y una sola sesión por cita; inicio/cierre 200/409 y repetición 409. Reportes: dos 200, un reporte completo con último escritor A/B, sin control optimista por versión. Chat: dos 200 y mismo ID nuevo; dos mensajes persistentes. Son dos solicitudes acotadas, no pruebas de carga.

Reprogramación, confirmación profesional, inicio anticipado 409 e inasistencia anticipada 409/final NO_ASISTIO pasaron sobre IDs nuevos. Padre no confirma (403). Familia y profesional ajenos: 404 en paciente/cita/sesión/reportes/PDF. ADMIN: 403 en chat. Suspensión y cambio de contraseña de cuentas nuevas revocan sesiones; reactivación no revive tokens. Relogin recupera el reporte guardado.

/health comprueba el proceso; /health/ready obtuvo 200 con SELECT 1 real. Errores 503 de commit/pool/rollback se prueban en unidades con dobles explícitos; no se apagó Supabase. Expiración probada en unidad, sin esperar 24 horas ni alterar sesiones reales. PDF familiar nuevo, firma %PDF y campos sanitizados, generado por backend; no firma clínica ni datos reales.

05. APIs no operativas y capacidades faltantes

No se observaron APIs rotas al finalizar los recorridos ensayados. 401/403/404/409/422 esperados son protecciones correctas. 429/503 se probaron en aislamiento sin fuerza bruta ni caída real de Supabase. Los dos DELETE físicos no están verificados; no se califican como rotos.

Capacidad	Estado real	Siguiente acción
Mínimo privilegio B02	Pendiente; rol actual amplio	Responsable revisa B02_MINIMO_PRIVILEGIO.md y aprueba rol/GRANT/RLS explícitos; verificar el núcleo con ese rol.
Producción/credenciales B03	Guardas de código probadas; infraestructura y rotación pendientes	Definir proxy/dominios, coordinar rotación y probar navegador en HTTPS final.
Recuperación/backup B06	Concurrencia acotada probada; caída/restauración/carga sin certificar	Ensayo autorizado y evidencia propia antes de afirmar disponibilidad.
Protección en réplicas	Limitador local a un proceso	Gateway o almacenamiento compartido revisado antes de escalar.
DELETE físicos	Sin ensayo por autorización actual	Conservar rutas; futura autorización y entorno apropiado sin personas reales.
Juegos, voz, IA, WebRTC, firma, consentimientos y recuperación pública	Prototipos/ausencia previamente documentados; fuera de esta corrección	No ampliar alcance ni afirmar persistencia nueva.
Mensajería	Operativa y probada; no un faltante	Mantener permisos; idempotencia y escritores externos siguen limitaciones.
Pagos	Excluidos por profesor	Sin desarrollo ni commits de cobros, reales o simulados.

Registros nuevos retenidos, primera cohorte: usuarios 52-56, pacientes 87/88, tratamientos 7/8, citas 4/5, sesiones 3/4, chat 2. Cohorte final: usuarios 57-61, pacientes 89/90, tratamientos 9/10, citas 6/7, sesiones 5/6, chat 3. Mensajes/reportes sintéticos: excluir de métricas clínicas. No borrar ni tocar registros de auditorías anteriores. Bootstrap ADMIN solo inició/cerró sesión para altas; no se editó su cuenta.

06. Seguridad y riesgos priorizados

Hallazgo	Estado y evidencia	Riesgo pendiente / responsable
B01 TLS	Resuelto para destino actual: cadena/nombre, TLS 1.3 y confianza incorrecta rechazada	CA 2021 con opt-in de formato; sustituir cadena cuando sea compatible con STRICT. Sin fallback inseguro.
B02 privilegios	Pendiente; bypassrls/createdb/createrole siguen true	Propuesta lista, no aplicada. Quitar solo BYPASSRLS bloquearía el núcleo con RLS sin políticas.
B03 producción	Parcial: configuraciones inseguras rechazadas; cookies/origen HTTPS en unidades	Desarrollo para HTTP local; HTTPS público y rotación de cuentas anteriores pendientes.
B04 abuso	Resuelto en alcance de un proceso: límites, 429/Retry-After, recuperación y capacidad probados	No distribuido; reinicio vacía estado. Ataques desde varias IP no certificados.
B05 contratos	Resuelto: reglas compartidas, entradas 422 por ambas familias, parcial/null y datos antiguos	No migración ni cambios de contraseñas de cuentas anteriores. No todos los payloads ensayados.
B06 concurrencia/operación	Parcial: reservas/sesión/transicione s/reportes/chat y persistencia real; errores en unidades	Escritores externos, restauración, caída real y carga pendientes. Sin idempotencia/UNIQUE de pareja nuevos.

B02 propone rol runtime
NOBYPASSRLS/NOCREATEDB/NOCREATEROLE/NOSUPERUSER/NOREPLICATION/NOINHERIT, sin propiedad ni membresías administrativas. Permisos por tabla/operación y USAGE solo en secuencias de tablas con INSERT; políticas exclusivamente TO el rol runtime. USING true para ese backend no aísla familias dentro de PostgreSQL: autorización por recurso permanece en FastAPI. Sin políticas públicas, Supabase Auth ni revocaciones globales. Falta aprobación específica y verificación del nuevo rol. Referencia: <https://www.postgresql.org/docs/current/sql-createpolicy.html> .

Credenciales/bootstrap y CA permanecen fuera de Git. Guiones nuevos no incluyen valores secretos; credenciales generadas están en tmp ignorado. Informes/evidencia compartida no contienen tokens, hashes, contraseñas ni datos clínicos reales. V20 fue revisado contra secretos configurados, diff y referencias remotas; sin force-push.

07. Evidencia de validación y límites

Verificación	Resultado nuevo	Evidencia y límite
verify_backend_readonly	TLS válido/negativo, READ ONLY, 19 modelos y 0 diferencias	database-readonly.json; metadatos, sin historias reales.
verify_hardening_journey	99 HTTP correctos con sesiones distintas	live-supabase.json; cohorte nueva autorizada.
verify_hardening_followup	29 HTTP correctos en la misma cohorte nueva	followup-supabase.json; lecturas, estado y revocación adicionales.
verify_hardening_persistence	SQL READ ONLY: conteos/estados/reporte y revocación correctos	persistence-readonly.json; no ausencia universal de huérfanos.
pytest, selección sin conftest	114 pass, 0 fail, 0 skip, 19 avisos	backend-unit.txt; dobles explícitos para producción/429/503. No sustituyen un fallo real por un mock.
pytest --collect-only	183 recolectadas	backend-collection.txt; 69 sin ejecutar, no declaradas aprobadas.
npm test	257 componentes + 25 rutas aprobados	frontend-tests.txt; no nuevas capturas UI ni cobertura de todas las pantallas.
tipos/check/build y pip check	Correctos; 320 fuentes frontend, máximo 495 líneas	diagnostics.json; aviso Node DEP0205. Build no significa hosting.
Graphify refresh/check	Mapa vigente, AST sin LLM	knowledge-refresh.txt / knowledge-check.txt; fallback secuencial Windows y 12 fuentes sin símbolos.
Diff/refactor/secretos/Git	27 cuerpos AST conservados; Python modificados hasta 499 líneas; V20 publicado	diagnostics.json; CI remoto no observado, no atribuirle las pruebas locales.

Comando backend desde backend: `.venv313/Scripts/python.exe -m pytest --noconftest -p no:cacheprovider tests/test_backend_hardening.py tests/test_auth_api.py tests/test_auth_security.py tests/test_config_isolation.py tests/test_mensajeria.py tests/test_report_pdf.py tests/test_models.py -q`.

Reproducción de lectura: `python -m scripts.verify_backend_readonly --output ../tmp/database-readonly.json`.
Escrituras: `python -m scripts.verify_hardening_journey --execute-authorized --output ../tmp/journey.json`, solo con autorización humana y credenciales ADMIN privadas. Complemento: `python -m scripts.verify_hardening_followup --execute-authorized --source ../tmp/journey.json --private [archivo privado generado] --output ../tmp/followup.json`.
Cotejo: `python -m scripts.verify_hardening_persistence --source ../tmp/journey.json --output ../tmp/persistence.json`.
Nunca apuntar fixtures destructivas a Supabase ni publicar el archivo privado.

Fallos de preparación registrados: TLS 92 por CA legacy; primera regresión auth 21 pass/2 fail por presupuesto compartido entre pruebas independientes, corregida aislando el limitador por caso sin bajar límites del runtime; npm spawn EPERM, resuelto por ejecución autorizada; segunda instancia 8000 rechazada por puerto ocupado, servicio existente retenido; identidad Git ausente, commit con identidad de Piero ya publicada. 19 avisos finales: deprecaciones Starlette/httpx/cookies en pruebas heredadas. Se conservan en diagnostics.json y logs sanitizados.

Criterio del profesor	Evidencia actual	Límite
Arquitectura/backend	Capas reales, 55 contratos, refactor compatible, ADR 0009 y núcleo HTTP	Rúbrica parcial: no inventar criterios ni nota oficial.
BD/modelo/operaciones	26 tablas, 34 FK, 26 PK, comparación ORM y persistencia sintética	Sin DDL, copias de pacientes reales ni aprobación de rol nuevo.
Seguridad y pruebas	Roles propios/ajenos, revocación, validación, concurrencia y TLS	Sin pentest, carga, certificación clínica, HTTPS final ni backup/restauración.

Evidencia heredada: auditoria-real-supabase-2026-10-09.md y Word backend 73/100; auditoria-2026-10-09-12.md/V18 frontend 94/100. No se recuperan implementación ni resultados de la continuación cancelada. Se partió de V19 publicado; el borrador del intento interrumpido de este chat se conservó y revisó con los resultados nuevos descritos aquí.

08. Cierre y ruta de entrega

V20 funcional publicado en dev y feat/piero-dev: b76a34a6125cae42614e9bee6da41ccc28163d7b. Desarrollo exclusivamente en piero-dev; publicación comprobada con ls-remote. Este informe, PDF, evidencia y complemento se publican en el cierre documental posterior; consultar Git/progreso para su SHA efectivo. La versión de commit V20 no es la versión de API 0.1.0.

Siguiente acción: responsable revisa y aprueba específicamente B02_MINIMO_PRIVILEGIO.md antes de crear rol/GRANT/políticas. Después verifica el núcleo bajo ese rol, coordina rotación de credenciales existentes, ensaya HTTPS/proxy/cookies y backup/restauración autorizados. Mantener una instancia hasta disponer de protección compartida. No se certifica un despliegue público con datos de menores.

Entregables: fuente docs/audits/auditoria-2026-10-09-13.md; PDF output/pdf/Auditoria_Backend_AshaKids_2026-10-09-13.pdf; evidencia docs/evidence/audit-2026-10-09-13/, índice/contexto/progreso y guías operativas. Manifest SHA-256 y validación PDF para integridad; páginas renderizadas y revisadas antes de entrega.

Las correcciones verificables dentro de la autorización quedan documentadas. B02/B03/B06 mantienen pendientes concretos: no afirmar 100%, producción pública ni aceptación completa de todas las pantallas. Repositorio: <https://github.com/sromansilva/ashakids-platform> .